

Tenant isolation and safe operational records

Policy intent

Protect source bindings and avoid sensitive content in a synthetic investigation. Opaque identifiers are not permission to join unrelated records. Tenant identity must accompany persistence, retrieval and every evidence-source boundary.

Platform Security owns access and secret-handling controls. Source owners must return bounded records for the requested scope. The present synthetic identity headers are caller-supplied context, not production authentication.

Document control	Value
Key / version	PL-104 / 1.0.0
Document ID	9fe80dac-c724-4d63-a1fc-77a0ff993ea3
Owner	Platform Security
Tenant ID	8b860d80-d17f-4e6b-8c48-af35f26a4d61
Status / effective	APPROVED / 2026-10-01
Approver	Knowledge Approver (fictional role)
Scope	cross-stage
Risks / sources	R22, R23, R20 / E01, E02, E10, E11

Synthetic notice: All systems, records, roles and amounts are fictional. Guidance is advisory and never executes an action.

Mandatory isolation and data controls

Binding and scope

Every source lookup/result must carry tenant identity and explicit operation or window scope. Foreign-tenant or unrelated operation records must not be used to support a claim. A correlation failure must remain a safe failure or missing record, not a fallback query across all tenants. UUID similarity, amount similarity and nearby timestamps are not sufficient operation linkage.

Snapshots and citations must retain source/version and exact bounded identity. The analyst must verify those bindings rather than accepting model-supplied source descriptions. Retrying a failed source must preserve previous attempt outcomes. Approved guidance must remain scoped to its tenant and applicable domain.

Sensitive content

Only synthetic records, fictional role accounts and SYN_UNIT amounts are permitted. Real cardholder, bank, customer or merchant data must not enter prompts, sources, reports, logs or audit details. Credentials, private endpoints and raw sensitive payloads must not be requested as diagnostic evidence. Bounded failure categories and safe context are sufficient for access investigation.

Access, certificate or credential failures must not authorize weakening controls, disabling verification, rotating secrets through the copilot or exposing tokens. The responsible owner may use a separately controlled procedure outside this product. A report cannot execute it or confer an access role.

Current identity boundary

Caller-supplied synthetic headers must not be described as authenticated production identity. Existing tenant-scoped checks remain required. Future authentication and source schemas need explicit architecture decisions and independent isolation tests.

Accountability and non-compliance

Role responsibilities

Role	Required control
Platform Security	Review access failure context and prevent secret exposure/bypass
Source Owner	Enforce tenant/scope binding and preserve safe failure metadata
Payment Operations	Exclude foreign records and retain linkage gaps
Knowledge Approver	Keep synthetic notices and safe references in every controlled document

Exception boundary

No exception permits real payment data, foreign-tenant evidence, credential disclosure or autonomous operational action. If a safe diagnostic field is unavailable, retain the gap and escalate to its owner. Do not recover evidence through a wider unsafe query.

If sensitive or foreign records appear, stop using them as report inputs and record the safe bounded incident through human review. Do not copy the payload into a second audit record to prove the problem. Remediation requires a separately authorized procedure; original audit provenance must not be silently rewritten.

Review and records

Retain safe source/scope IDs, failure category, exclusion reason and owner checkpoint. Review on identity, tenant boundary, source retention or logging changes. Future sources must test foreign-tenant lookups and safe not-found behavior, malformed input, unsupported filters and unrelated operation linkage. E02/E10/E11 remain future requirements; only aggregate E01 is currently exposed by MCP.

Related guidance and revision

Related documents: PL-101, PL-105, RB-110, RB-111.

Version 1.0.0, effective 2026-10-01. Initial independent risk-derived issue. Review cadence: annual, or before a material domain/source/control change.